SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Gürmak CNC Component X (kontrolcü firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet, etkiliyor: (1) bileşen var, kontrolcü firmware kütüphanesi; (2) sürüm 2.4 listede (bülten aralığı doğrulanır); (3) uzak servis internete açıksa ulaşılabilir. SBOM'dan teyit edilir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hemen durdurmam; önce uzak servis modülünü kapatır/ağdan ayırırım. Tanınmayan oturum veya parametre değişimi varsa Lab 6 akışına geçilir: önce emniyet, sonra kanıt.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: yedek alınır, yama üretici onaylı yedek kontrolcü/test makinesinde denenir (program, eksen, ATC, emniyet), sonra planlı bakım penceresinde uygulanır; geri alma planı hazır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Yama notunda kapı girişi/STO/hız izleme/parametre depolama var mı bakılır; öncesi-sonrası emniyet parametre raporu ve checksum karşılaştırılır. Fark veya şüphe varsa kapı, acil stop, durma süresi, SLS yeniden doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak servis varsayılan kapalı + VPN/MFA/jump server; kontrolcü ayrı bölgede, güvenlik duvarında yalnız zorunlu port; USB/DNC kısıtı; parametre değişikliği izleme ve alarm; yama için tarihli istisna kaydı.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.